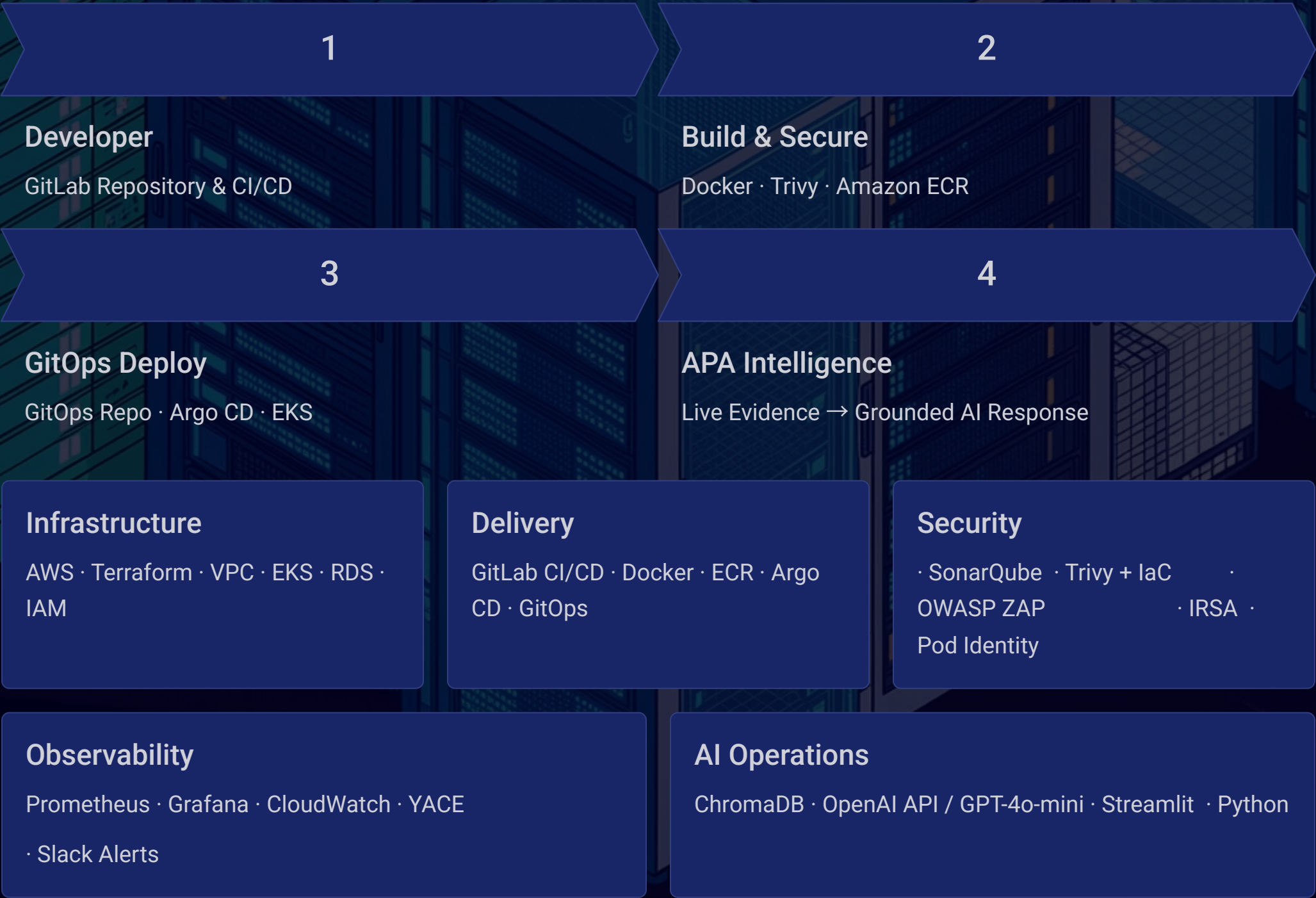


# AFM – GitOps DevSecOps Cloud Project

PORTFOLIO · DEVSECOPS · CLOUD · GITOPS

## AI-Assisted Platform Operations with AFM Platform Assistant (APA)

AFM is an end-to-end GitOps and DevSecOps portfolio project built on AWS Cloud. The platform demonstrates Infrastructure as Code with Terraform, automated CI/CD pipelines using GitLab, layered DevSecOps security with SAST, dependency and container scanning, Terraform IaC scanning, and post-deployment DAST with OWASP ZAP, GitOps-based deployments with Argo CD, Kubernetes observability with Prometheus, Grafana, CloudWatch, YACE, and Slack alerting, and cloud-native operations on Amazon EKS. The platform also includes the AFM Platform Assistant (APA), an AI-assisted operations capability that combines RAG-based knowledge, ChromaDB, live Kubernetes and AWS read-only evidence, and OpenAI GPT-4o-mini to provide grounded operational analysis and recommendations.



AFM / GitOps / DevSecOps / AWS EKS / AFM Platform Assistant (APA)

# Executive Summary

## What AFM Demonstrates

AFM is a production-inspired DevSecOps portfolio project demonstrating how a modern engineering team provisions cloud infrastructure, builds and secures applications, manages infrastructure as code, deploys through GitOps, operates workloads on Amazon EKS, and integrates AI into platform operations — all while maintaining strict security boundaries and using evidence rather than assumptions.

01

## Infrastructure as Code

02

## GitLab CI/CD

03

## DevSecOps Security

04

## GitOps Deployment

05

## Amazon EKS Runtime

06

## Production-Style Observability

07

## AI-Assisted Platform Operations

08

## Read-Only Live Infrastructure Intelligence

09

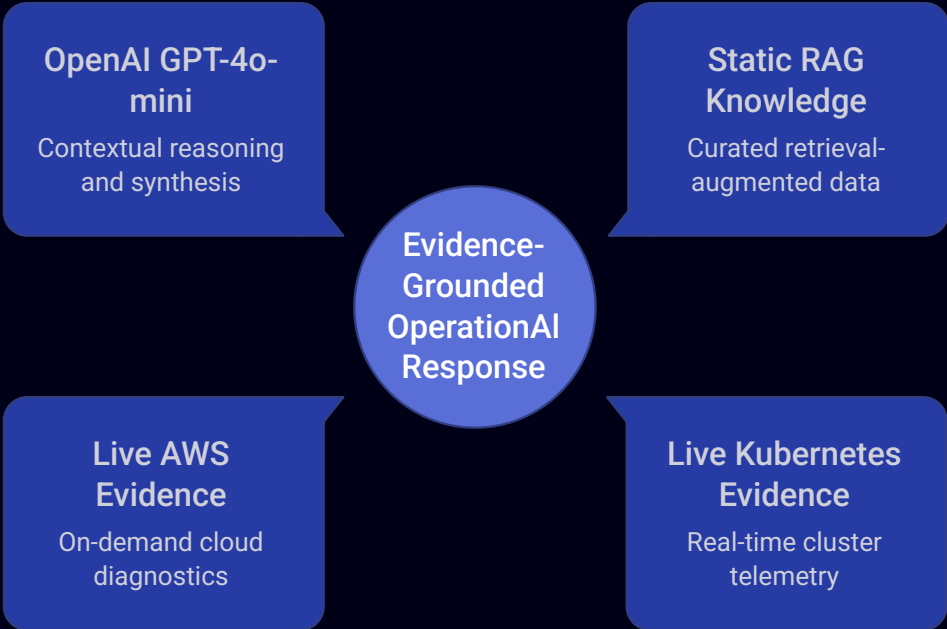
## Cost-Aware Engineering

10

## Human-in-the-Loop Control

## APA Intelligence Layer

The AFM Platform Assistant (APA) is an additional intelligence layer integrated into the existing DevOps platform. It combines static RAG knowledge with live infrastructure evidence to produce grounded operational responses.



⊗ **APA is strictly read-only.** APA cannot create, modify, delete, restart, scale, patch, deploy, apply, sync, execute infrastructure-changing commands, execute kubectl mutation commands, execute Terraform apply, perform Argo CD sync, or write to AWS. The platform remains controlled by Terraform + GitLab CI/CD + GitOps + Argo CD + Human engineering control.

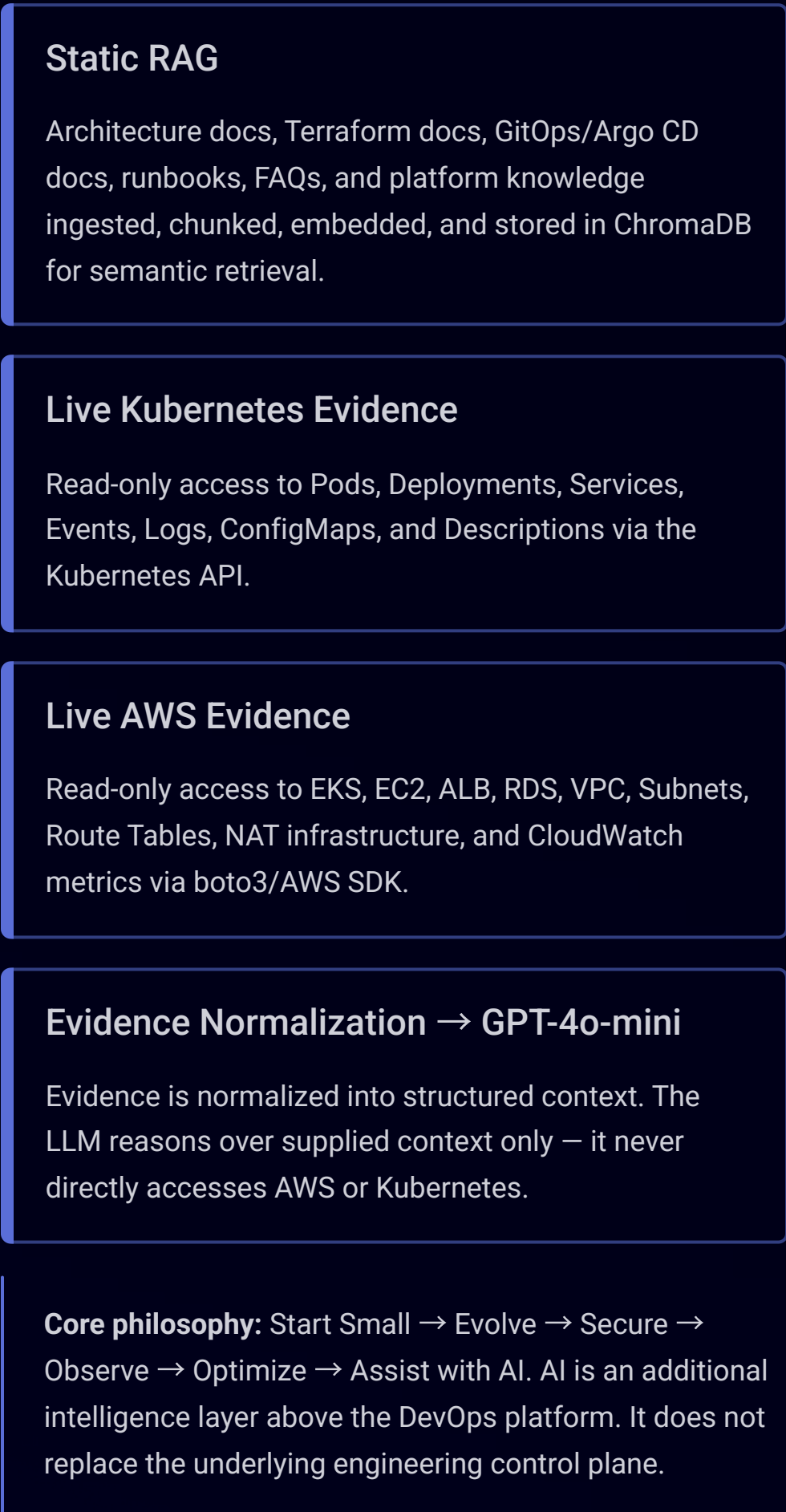
# From DevSecOps Platform to AI-Assisted Platform Operations

Traditional DevOps platforms provide CI/CD, infrastructure automation, Kubernetes deployment, monitoring, alerting, and security controls. Yet engineers still spend significant time searching documentation, finding runbooks, checking Kubernetes resources, investigating incidents, correlating logs and events, and gathering evidence from multiple systems. The APA intelligence layer directly addresses this operational friction.

## Traditional DevOps Foundation



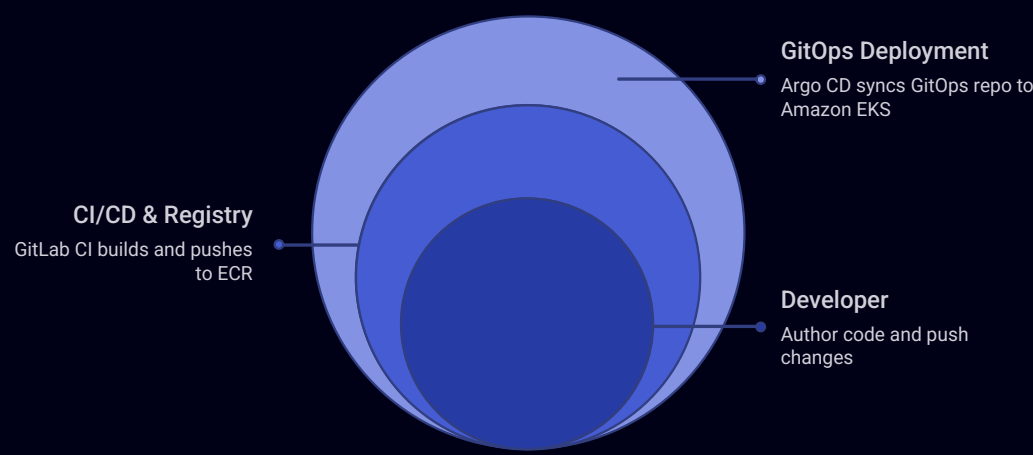
## AI-Assisted Operations Layer — APA





# High-Level GitOps DevSecOps Platform Architecture

## Primary Delivery Path



## AWS Platform Services

### Network

VPC · Public Subnets · Private Subnets · IGW · NAT Instance · ALB · ACM · Route 53

### Data

RDS PostgreSQL · AWS Secrets Manager · Amazon S3 · Amazon ECR

### Observability

Prometheus · Grafana · Alertmanager · CloudWatch · YACE · Slack

## Amazon EKS Cluster · 2 Dedicated Worker Nodes

### AFM Worker Node — t3.medium

**Namespace:** afm-bank

- frontend-ui
- login-service
- registration-service
- auth-service
- other AFM workloads

**Identity:** IRSA → OIDC Provider → IAM Role

### APA Worker Node — t3.medium

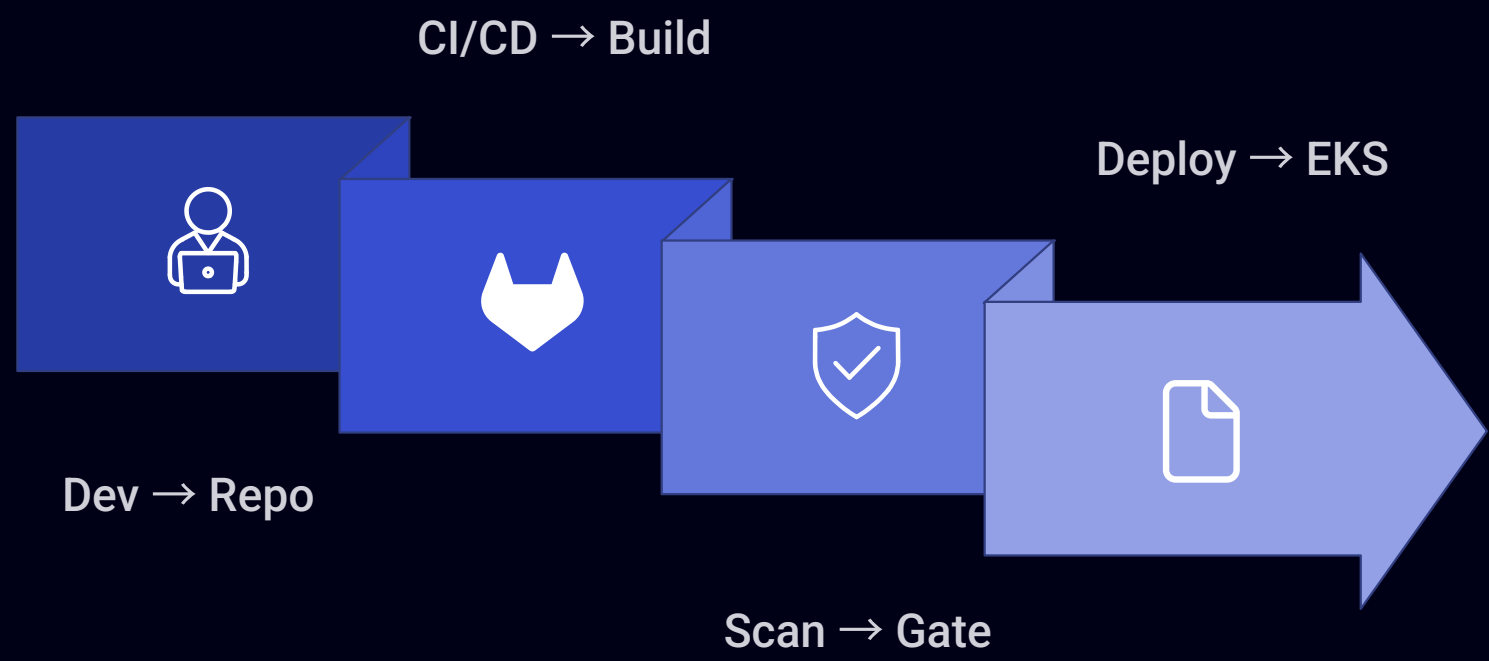
**Namespace:** afm-platform-assistant

- Streamlit UI
- APA Application
- RAG (ChromaDB)
- LLM Integration
- Kubernetes read-only integration
- AWS read-only integration

**Identity:** EKS Pod Identity → Read-Only IAM Role

- ❏ **Identity distinction:** AFM workloads use IRSA. APA uses EKS Pod Identity with a dedicated read-only IAM role. These are separate, distinct identity flows.

# GitOps DevSecOps Delivery Lifecycle



## CI/CD Responsibilities

- 1

Source checkout

GitLab repository clone and workspace preparation.
- 2

Application build & validation

Build steps and tests/validation where implemented.
- 3

Docker image build

Immutable container image construction from Dockerfile.
- 4

Trivy container scan

Security quality gate – scan before push to registry.
- 5

Push to Amazon ECR

Immutable image published to private container registry.
- 6

Update GitOps desired state

CI updates image tag in GitOps repository to trigger reconciliation.

## Security Lifecycle

- Trivy Container Scan

Container image vulnerability scanning integrated as a CI/CD quality gate. Images failing the gate are not promoted to Amazon ECR.
- Trivy IaC Scan

Terraform infrastructure-as-code scanning for misconfigurations before Terraform Plan and Controlled Apply.
- OWASP ZAP

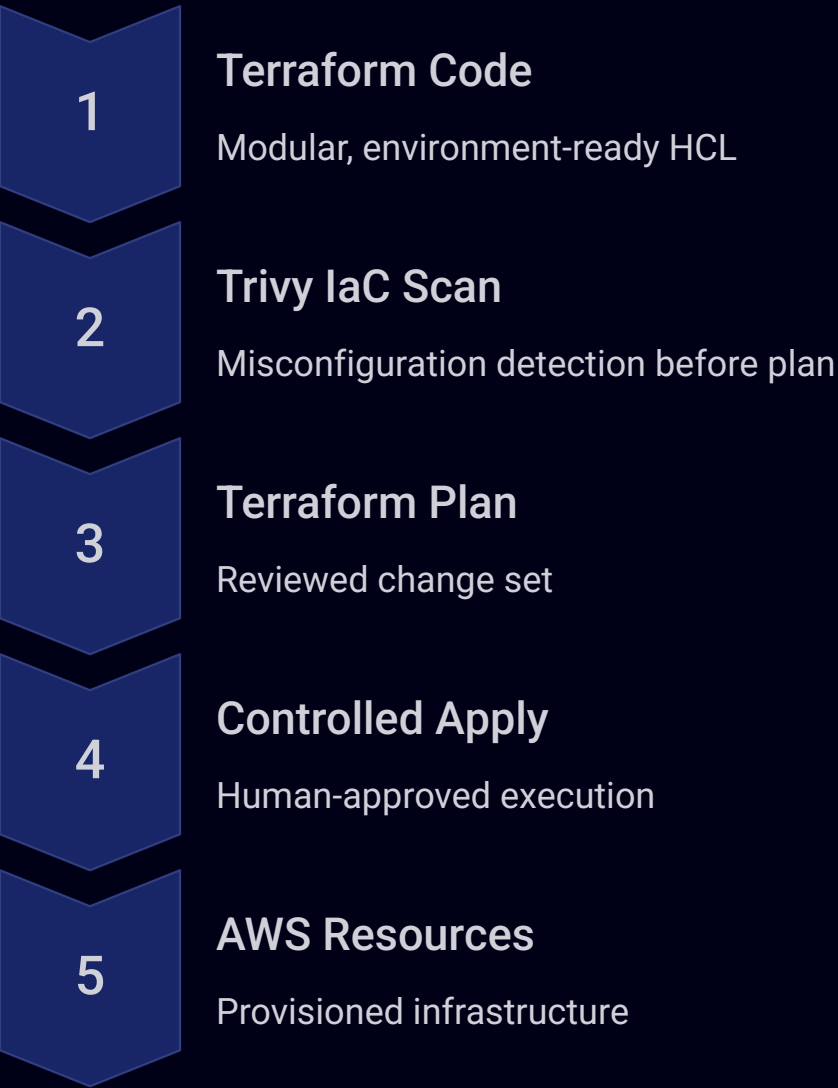
Post-deployment runtime Dynamic Application Security Testing (DAST) against deployed services.

## GitOps Control Principle

CI builds and publishes artifacts. CI updates desired deployment state. The GitOps repository represents desired Kubernetes state. Argo CD continuously reconciles desired state with Amazon EKS. **APA does not perform deployment.** Deployment remains controlled by the GitOps + Argo CD workflow.

# Infrastructure as Code – AWS Platform Managed by Terraform

Major AWS infrastructure is managed through modular Terraform using an environment-ready architecture. Terraform state is stored in Amazon S3 remote state with S3 native locking (`use_lockfile`), enabling environment-specific deployments.



## Networking – VPC 10.0.0.0/16

| Resource         | CIDR / Detail                          |
|------------------|----------------------------------------|
| Public Subnet A  | 10.0.1.0/24                            |
| Public Subnet B  | 10.0.2.0/24                            |
| Private Subnet A | 10.0.3.0/24                            |
| Private Subnet B | 10.0.4.0/24                            |
| NAT Instance     | t3.micro                               |
| Internet Gateway | Route Tables · Security Groups · NACLs |

## Compute

- Amazon EKS – AWS managed control plane
- 2 dedicated t3.medium worker nodes
- AWS Load Balancer Controller

## Data & Storage

### RDS PostgreSQL 15

db.t3.micro · 20 GB gp3 · Single-AZ

### Amazon S3

Object storage + Terraform remote state with S3 native locking

### Amazon ECR

Private container image registry

## Security, Identity & Observability

### Identity

IAM · OIDC/IRSA for AFM · EKS Pod Identity for APA · AWS Secrets Manager · External Secrets Operator

### Observability

Prometheus · Grafana · Alertmanager · CloudWatch · YACE

# Amazon EKS – Application and APA Runtime Architecture

ONE AMAZON EKS CLUSTER · 2 DEDICATED WORKER NODES · US-EAST-1 · AFMCLOUD.IN

## AFM Worker Node — t3.medium

Namespace: afm-bank

Frontend-ui

Login-service

Registration-service

auth-service

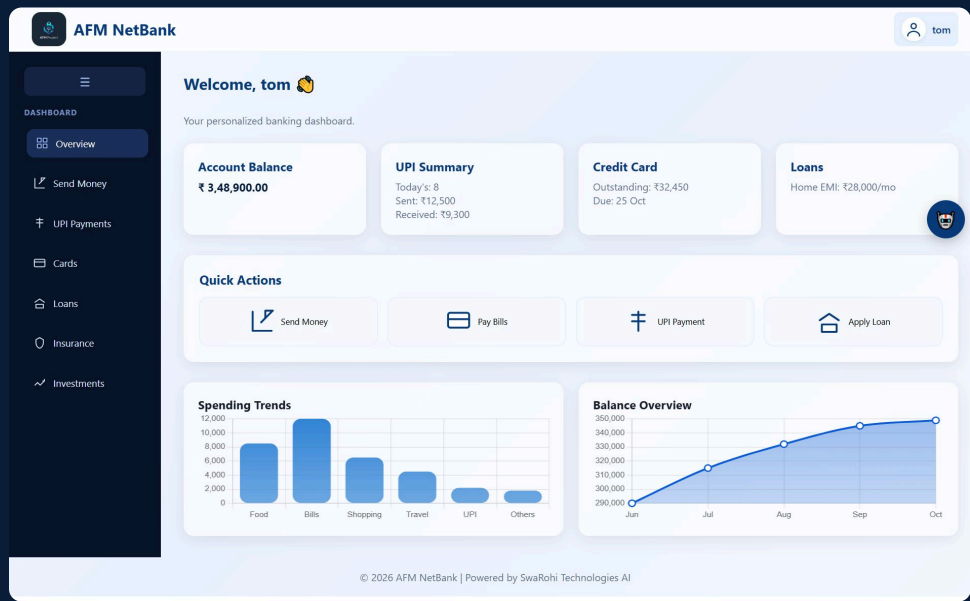
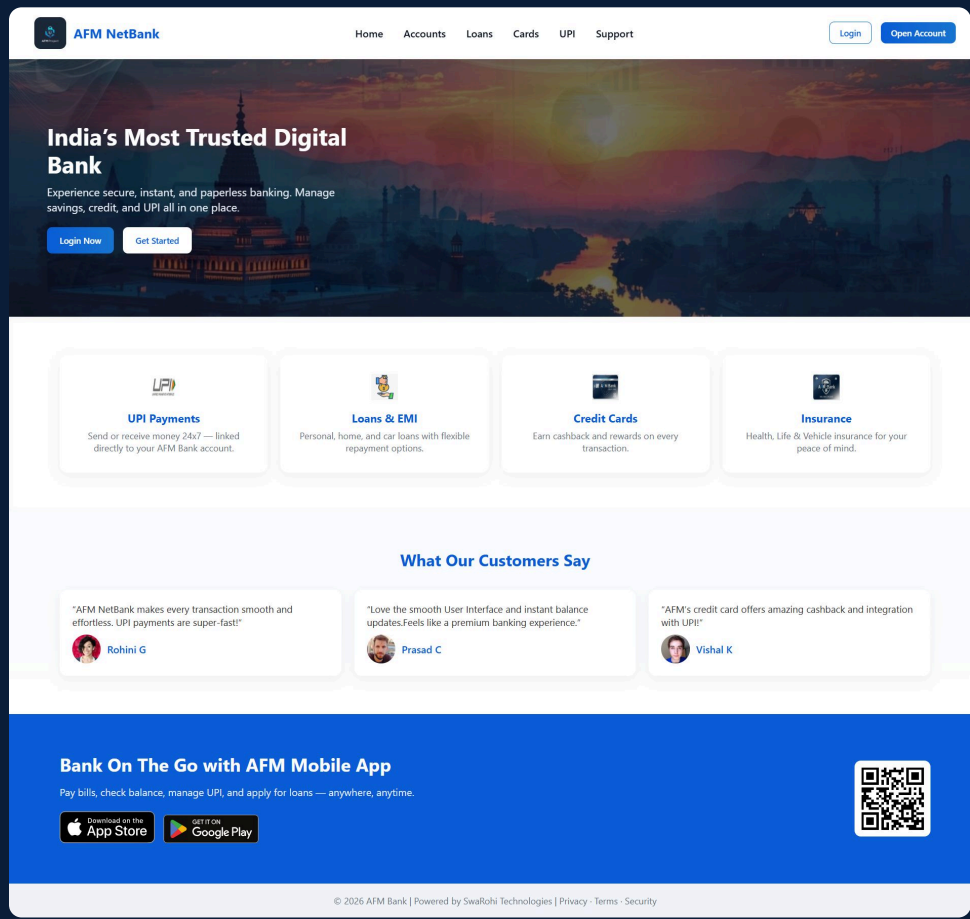
+ other AFM pods

### Kubernetes Objects

- Deployment · ReplicaSet
- ConfigMap · Secret
- ServiceAccount · Service · Ingress

## AFM Identity & Application Evidence

AFM Pod → Kubernetes ServiceAccount → IRSA → OIDC Provider → IAM Role → AWS Resources



## APA Worker Node — t3.medium

Namespace: afm-platform-assistant

Streamlit UI

Web-based conversational interface for platform engineers.

APA Application / Dynamic Router

Routes queries to STATIC, DYNAMIC, HYBRID, or BLOCKED paths.

RAG (ChromaDB)

Document ingestion, text chunking, embeddings, and semantic retrieval.

LLM Integration

OpenAI GPT-4o-mini generates grounded responses from supplied RAG and live read-only infrastructure evidence.

Kubernetes Read-Only Integration

Pods · Deployments · Services · Events · Logs · ConfigMaps

AWS Read-Only Integration

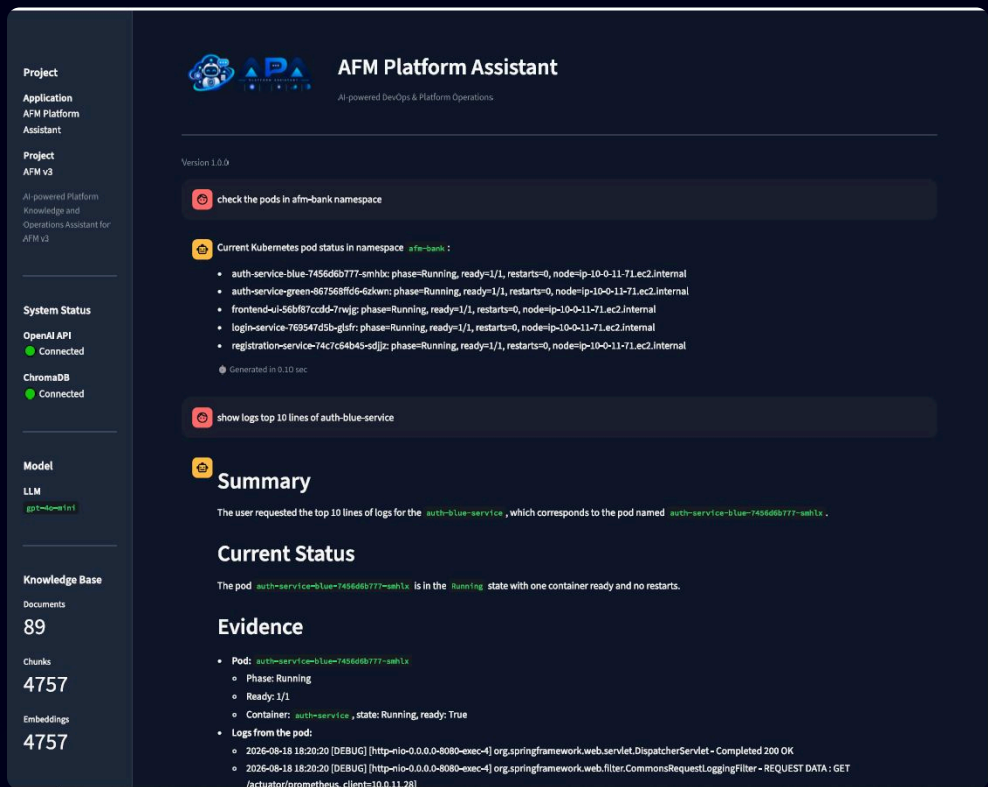
EKS · EC2 · ALB · RDS · VPC · CloudWatch via Boto3

- The APA workload is isolated on a dedicated EKS worker node to separate platform-assistant workloads from AFM application workloads, reducing resource contention and providing clear workload isolation. Both nodes are part of the same Amazon EKS cluster.

## Identity: EKS Pod Identity

APA Pod → Kubernetes ServiceAccount → EKS Pod Identity → APA Read-Only IAM Role → AWS APIs

APA StreamLit UI





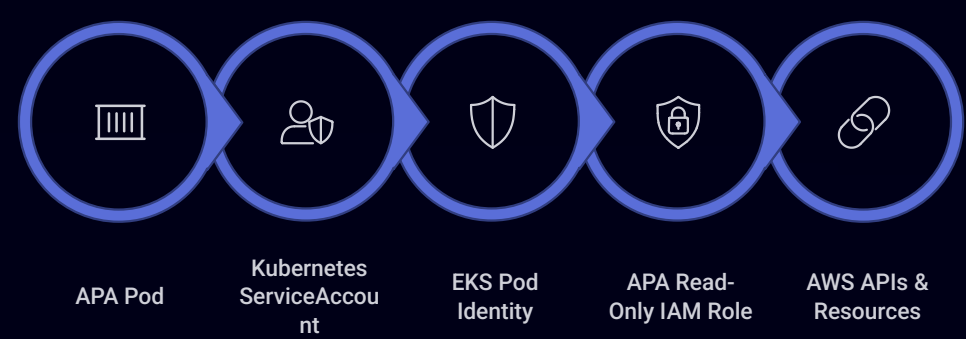
# Security by Design – Separate AFM and APA Identity Models

## Flow 1 – AFM Workloads (IRSA)



AFM workloads use IRSA (IAM Roles for Service Accounts) where AWS workload access is required. The OIDC provider federates the Kubernetes ServiceAccount token to an AWS IAM Role, granting scoped AWS permissions without hardcoded credentials.

## Flow 2 – APA Workload (EKS Pod Identity)



APA uses EKS Pod Identity – not IRSA. This is a distinct, newer AWS identity mechanism providing a dedicated read-only IAM role scoped exclusively to APA's approved evidence-retrieval operations.

## APA Permissions: **READ ONLY**

| Allowed               | AWS Scope                                                                       |
|-----------------------|---------------------------------------------------------------------------------|
| Describe · List · Get | EKS · EC2 · ALB · RDS · VPC · Subnets · Route Tables · NAT · CloudWatch metrics |

## APA Cannot:

- Create · Modify · Delete · Restart · Scale · Patch
- Deploy · Apply · Sync
- Execute Terraform apply
- Execute Argo CD sync
- Execute kubectl mutation commands
- Write to AWS

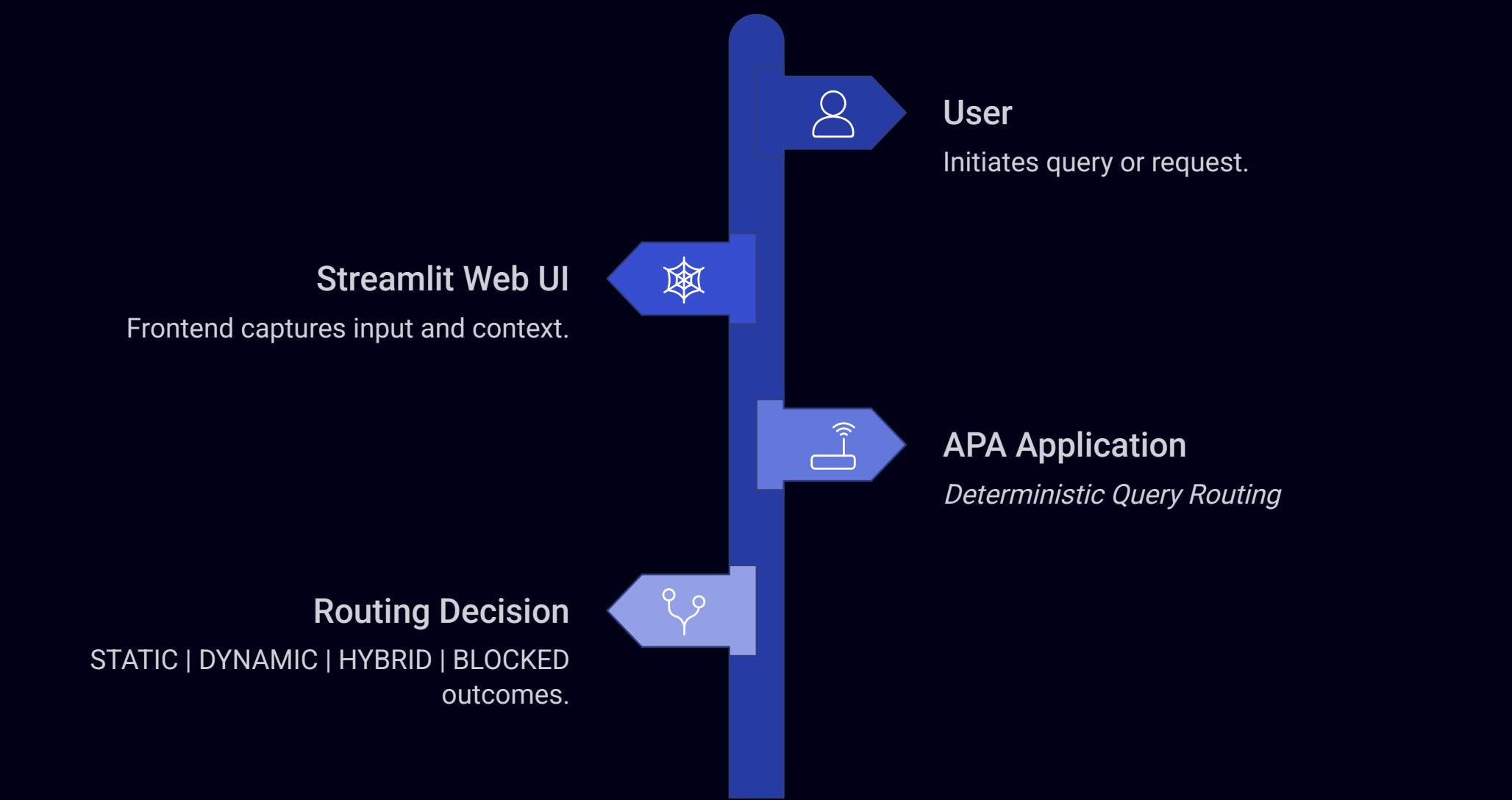
## Full DevSecOps Security Controls

|                                                                                     |                                                                                   |
|-------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| <b>No Hardcoded Credentials</b><br><br>All AWS access via IRSA or EKS Pod Identity. | <b>Least-Privilege IAM</b><br><br>Scoped roles per workload identity.             |
| <b>Kubernetes RBAC</b><br><br>Least-privilege Kubernetes access per namespace.      | <b>Trivy Scanning</b><br><br>Container image + IaC scanning in CI/CD.             |
| <b>OWASP ZAP</b><br><br>Post-deployment DAST runtime testing.                       | <b>Secrets Management</b><br><br>AWS Secrets Manager + External Secrets Operator. |
| <b>Audit Logging</b><br><br>CloudTrail + EKS audit logs.                            |                                                                                   |

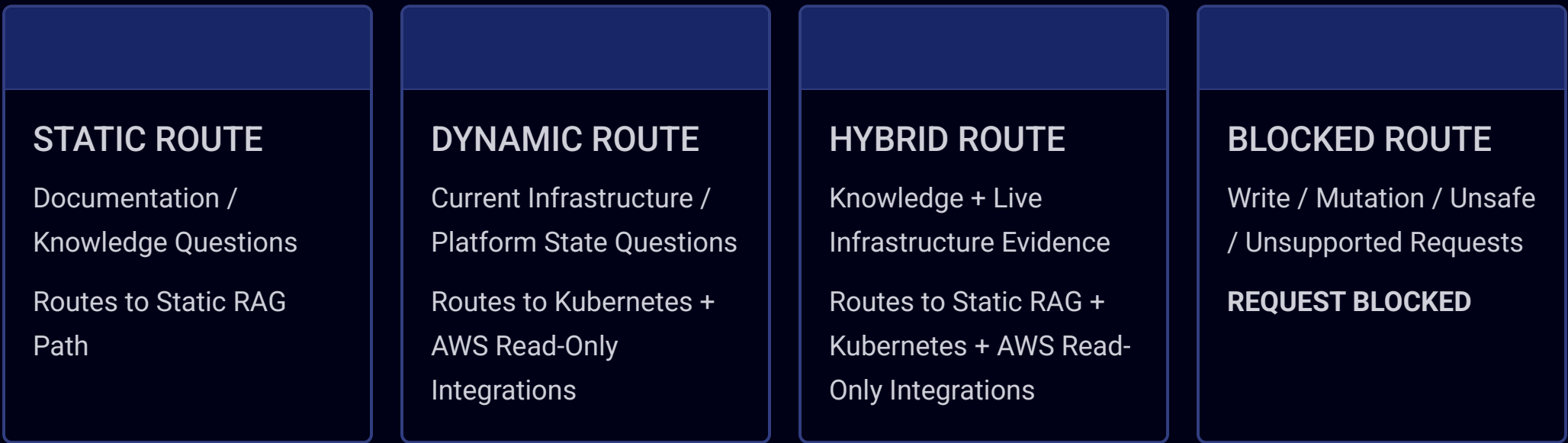


# AFM Platform Assistant (APA) – AI Operations Architecture

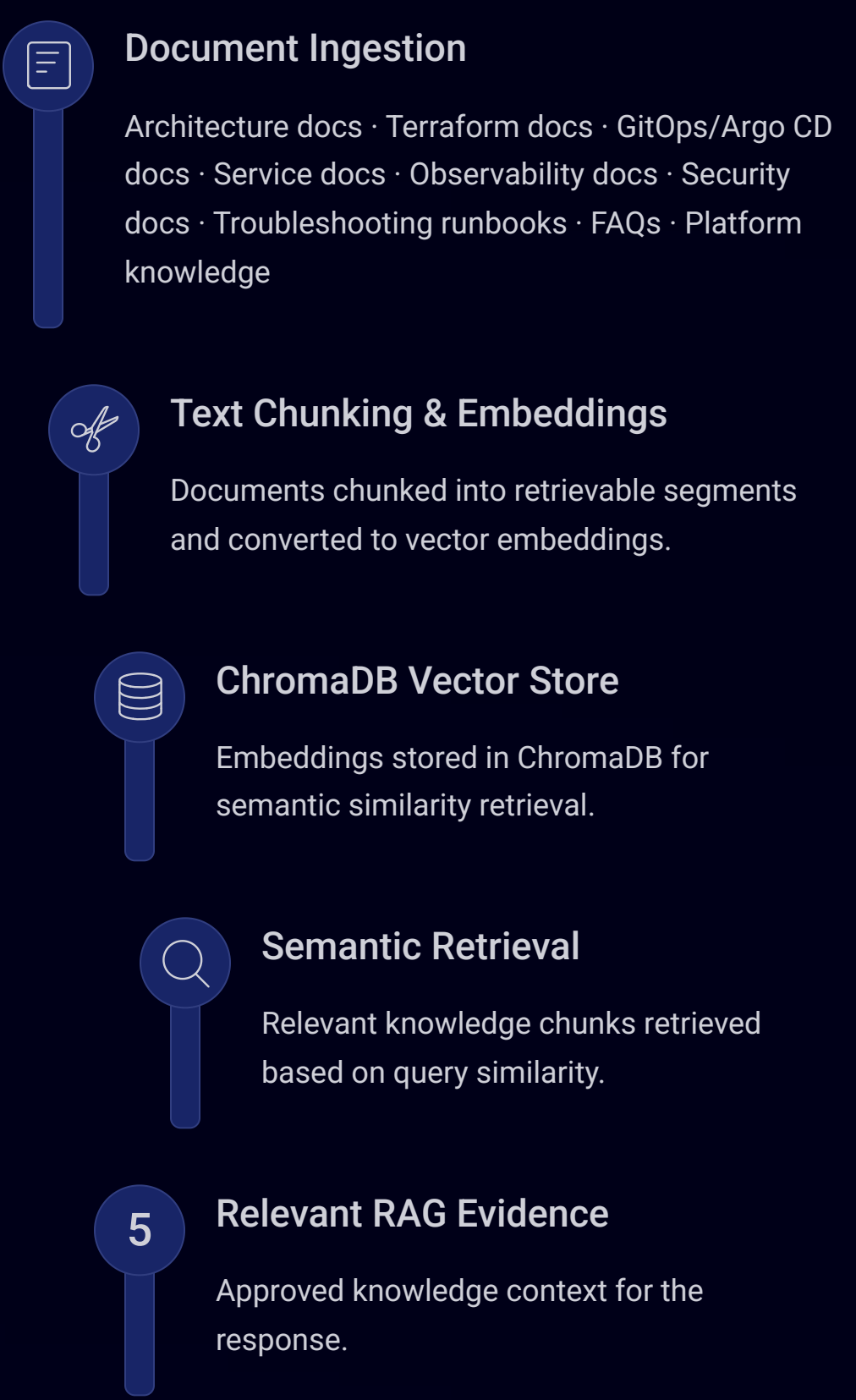
**Deterministic Query Routing:** User → Streamlit Web UI → APA Application / Dynamic Router → STATIC | DYNAMIC | HYBRID | BLOCKED



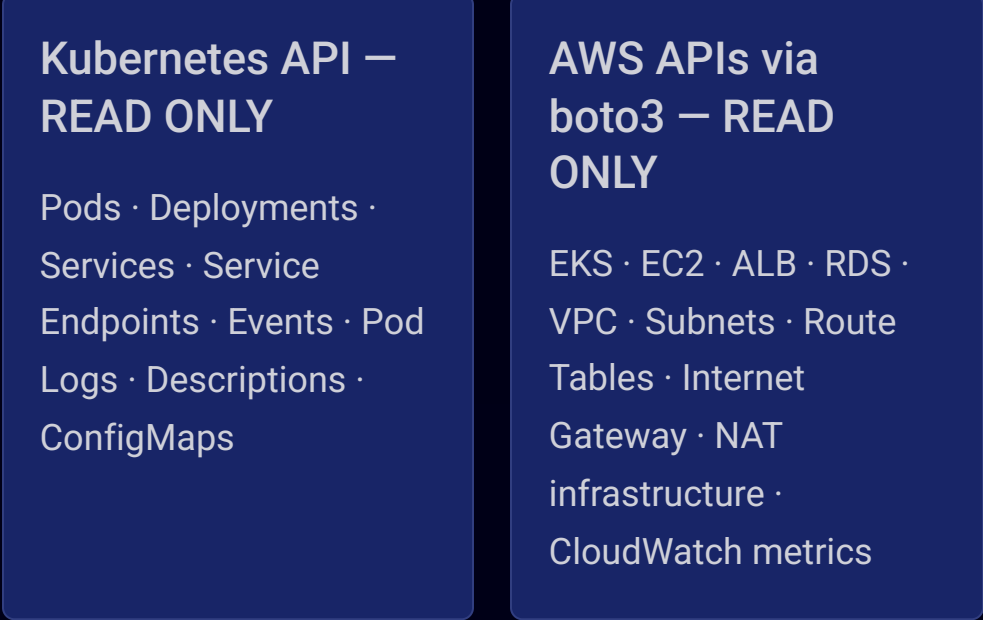
## Routing Decision Tree



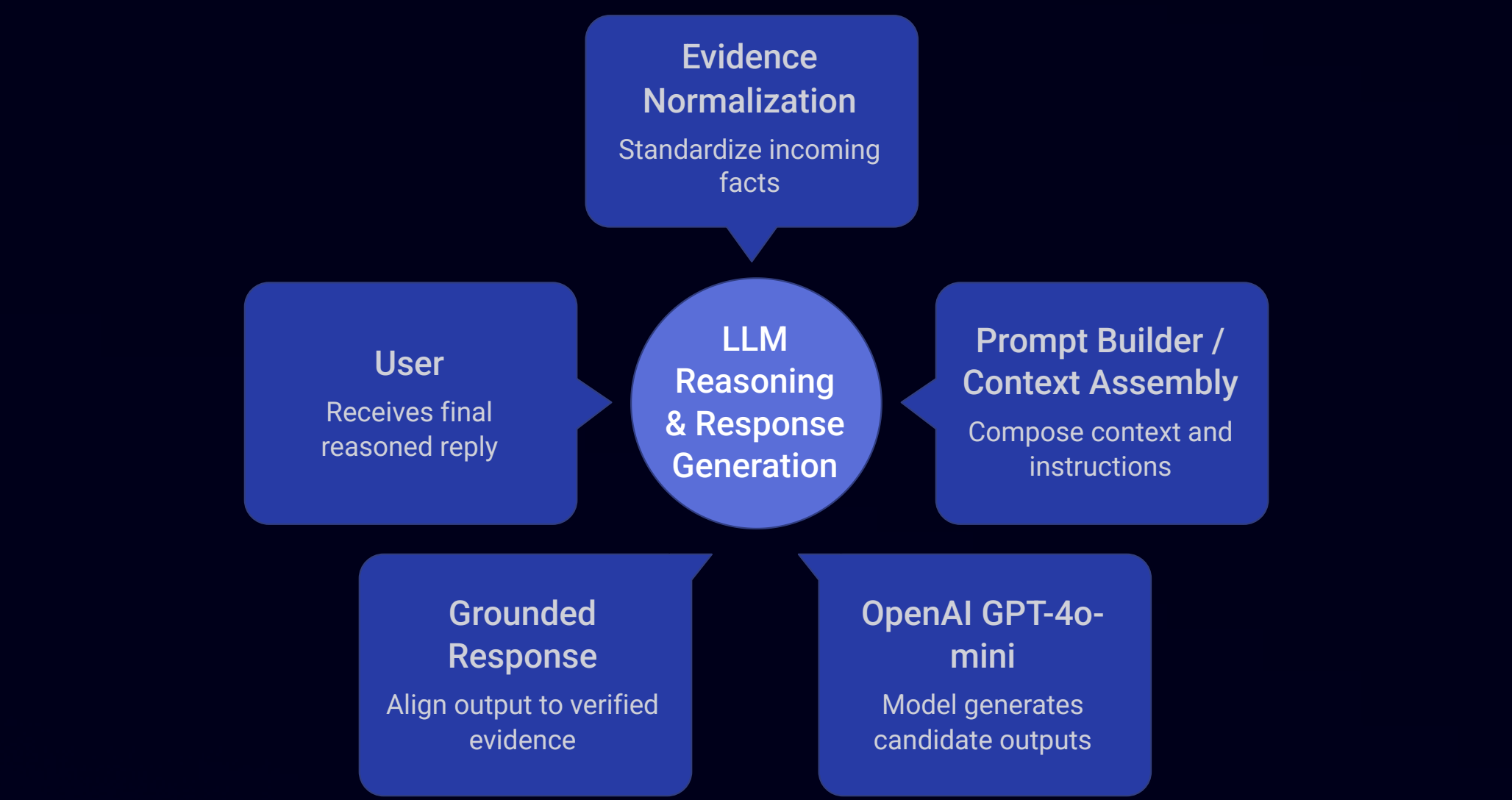
### Static Route — RAG Knowledge Base



### Dynamic Route — Live Evidence (Read-Only)



## Convergence Path



**CRITICAL SECURITY BOUNDARY**

The LLM does NOT directly access AWS or Kubernetes.

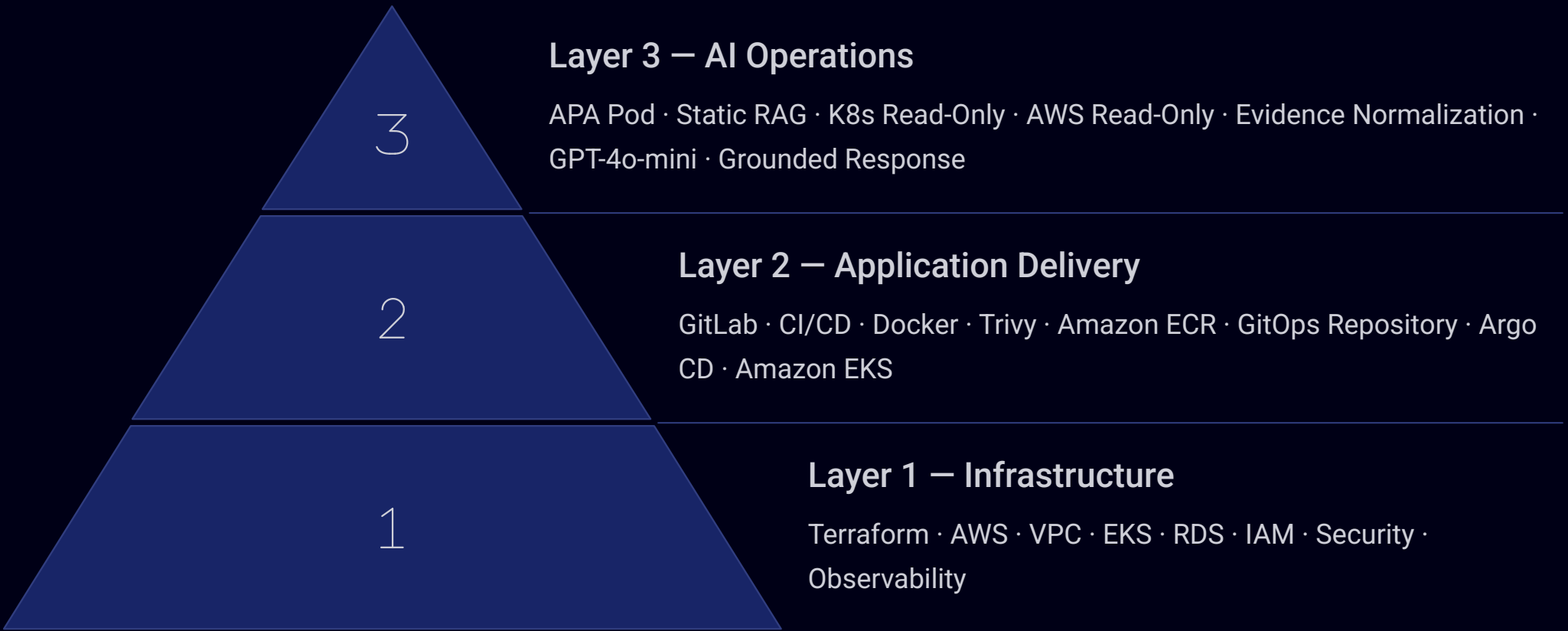
Correct flow: APA Read-Only Integrations → retrieve approved evidence → Evidence Normalization → structured context → Prompt Builder → OpenAI GPT-4o-mini.

The LLM reasons only over supplied context.

The LLM must NOT be depicted as directly connected to AWS APIs, Kubernetes API, Terraform, Argo CD, kubectl, or AWS resources.

# How AI Fits into the Existing DevOps Platform

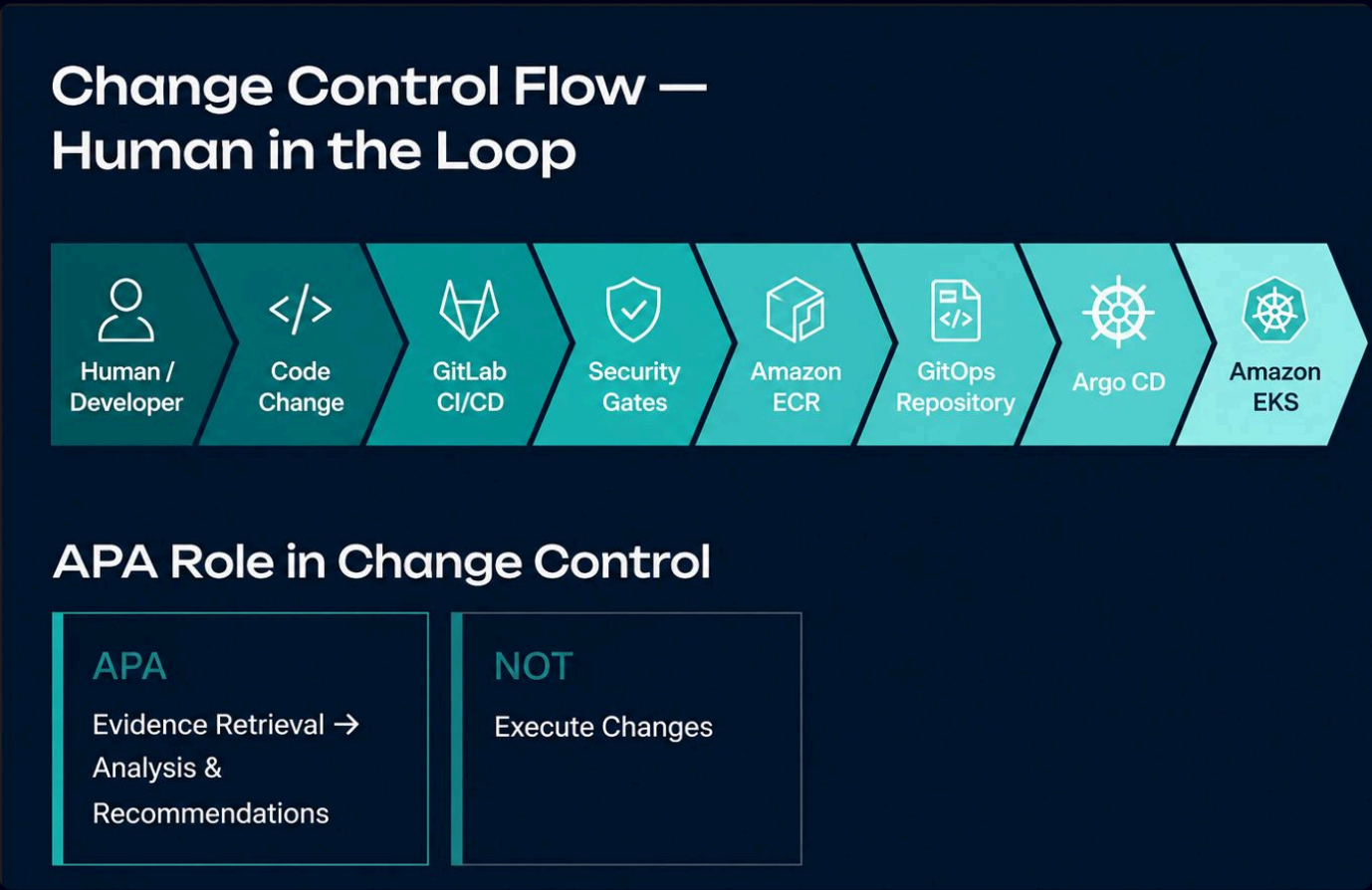
AI is integrated into the existing DevOps lifecycle as an additional intelligence layer — not a replacement for the engineering control plane.



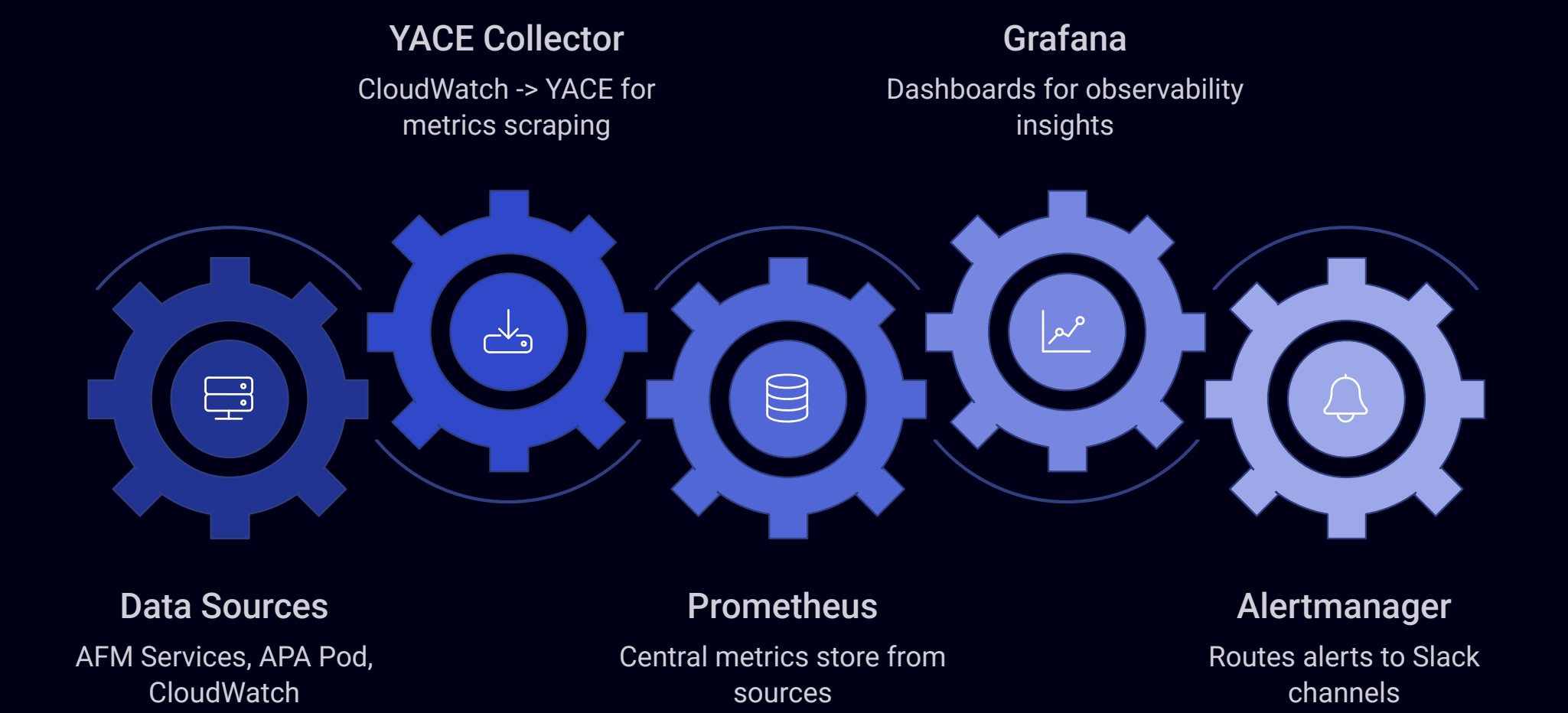
## Practical APA Use Cases

- 1 Incident investigation assistance**  
Surface relevant evidence from Kubernetes events, pod logs, and AWS metrics.
- 2 Kubernetes troubleshooting**  
Query pod state, deployment status, service endpoints, and recent events.
- 3 Architecture & infrastructure questions**  
Answer questions grounded in static RAG knowledge and live AWS resource state.
- 4 Runbook retrieval**  
Retrieve documented troubleshooting guidance from the knowledge base.
- 5 Service health investigation**  
Correlate pod health, AWS resource state, and CloudWatch metrics.

AF



# Observability & AI-Assisted Platform Operations



## Monitored Areas

| 1                                                                                                                                                                                                                                                              |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Application</b> <ul style="list-style-type: none"><li>• Service availability</li><li>• Pod health</li><li>• Request rate · Error rate</li><li>• 4xx / 5xx responses</li><li>• Latency</li></ul>                                                             |
| 2                                                                                                                                                                                                                                                              |
| <b>Infrastructure</b> <ul style="list-style-type: none"><li>• EKS health · Worker node health</li><li>• CPU / memory utilization</li><li>• ALB metrics</li><li>• RDS PostgreSQL metrics</li><li>• CloudWatch infrastructure metrics</li></ul>                  |
| 3                                                                                                                                                                                                                                                              |
| <b>APA Pod</b> <ul style="list-style-type: none"><li>• APA pod health</li><li>• API / application errors</li><li>• Resource utilization</li><li>• Evidence collection latency</li><li>• RAG latency · LLM usage</li><li>• AWS API evidence retrieval</li></ul> |

## Telemetry vs. Evidence — Complementary Layers

|                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                         |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Monitoring Telemetry</b> <p>Prometheus + Grafana + Alertmanager provide telemetry about <i>what is happening</i>.</p> <p><b>Example:</b> "Something is wrong with auth-service — error rate elevated, latency spiking."</p> | <b>APA Evidence</b> <p>APA provides conversational access to approved operational evidence and documented knowledge about <i>why and what to do</i>.</p> <p><b>Example:</b> ""Here is the available evidence about auth-service — recent Kubernetes events, relevant AWS infrastructure state, and applicable documented troubleshooting guidance."</p> |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**Human-in-the-loop control is maintained.** APA does not automatically execute remediation. APA surfaces evidence. Engineers act. The engineering control plane — Terraform + GitLab CI/CD + GitOps + Argo CD — remains the authoritative mechanism for all infrastructure and application changes.

### Observability Stack

Prometheus · Grafana · Alertmanager · CloudWatch · YACE · Slack · EKS audit logs · CloudTrail